SENTINEL | OT

COMPREHENSIVE VULNERABILITY ASSESSMENT

Cedar Ridge Regional Water Authority: Full External and Internal Vulnerability Assessment

DOCUMENT	Comprehensive Vulnerability Assessment Report
DATE	May 12, 2026
PREPARED BY	Sentinel OT
CLASSIFICATION	Confidential
REFERENCE	Report ID: pbcwud_cedar-ridge_sample_2026-05-12

Executive Summary

Sentinel OT conducted a comprehensive external and internal vulnerability assessment of the Cedar Ridge Water Treatment Plant operated by Cedar Ridge Regional Water Authority (CRRWA), serving approximately 14,200 residents. The assessment included passive external reconnaissance, on-site network mapping, controller integrity verification, and interviews with plant operations staff. Fieldwork was conducted May 5 through May 9, 2026.

The assessment identified **seven Critical findings**, **five High findings**, and **four Medium findings** across two internet-facing PLCs, one HMI workstation, one SCADA historian, one cellular gateway, one industrial radio, and the facility's internal OT network.

Three Critical vulnerabilities (CVSS 9.8) were confirmed on internet-exposed Rockwell Automation CompactLogix 1769-L18ER controllers. One of these, CVE-2021-22681, is listed in the CISA Known Exploited Vulnerabilities (KEV) catalog with a federal remediation deadline that has already passed. The on-site assessment validated all three external findings and confirmed that the controllers manage chemical dosing, filtration backwash sequencing, and clearwell level control.

Four additional Critical findings were identified during internal assessment:

- The HMI workstation runs an end-of-life operating system with no security updates since January 2025 and no endpoint protection.
- The SCADA historian database is accessible with default vendor credentials from any device on the flat OT network.
- No network segmentation exists between the PLC subnet, HMI workstation, historian server, and the cellular gateway. All devices share a single broadcast domain.
- Controller program integrity verification revealed that neither PLC has a documented backup. The last known program download occurred over 22 months ago, and no comparison baseline exists.

The combination of internet-exposed controllers, unpatched internal systems, flat network architecture, and no change management controls places this facility at severe risk. An attacker who gains access through any one of the external findings would encounter no additional barriers to reaching every device on the OT network.

> **Immediate action was initiated during this engagement.** Phase 1 compensating controls were applied on Days 1 through 3, eliminating direct internet exposure of the PLCs before on-site work

> began. The findings in this report now reflect validated post-compensating-control state alongside the full internal assessment.

Assessment Scope and Methodology

Scope

This assessment covered the complete operational technology environment at the Cedar Ridge Water Treatment Plant, including:

- All internet-facing assets identified through external passive reconnaissance
- Internal OT network architecture (PLCs, HMI, historian, networking equipment)
- Cellular gateway and radio telemetry configuration
- Controller program integrity
- Access controls, credential management, and change management practices

Out of scope: IT/corporate network, physical security, SCADA/HMI application logic review, and active penetration testing or exploitation.

Methodology

The assessment was conducted in two phases:

External Assessment (April 14 to 15, 2026). Passive reconnaissance using aggregated public intelligence sources. No packets were sent to CRRWA infrastructure. Findings were cross-referenced against the National Vulnerability Database (NVD), CISA Known Exploited Vulnerabilities catalog, and vendor advisories.

Internal Assessment (May 5 to 9, 2026). On-site assessment at the Cedar Ridge Water Treatment Plant. Methods included:

- Physical inspection of all OT network equipment, controllers, and workstations
- Network traffic capture and analysis (passive, non-disruptive)
- Controller firmware version and configuration verification via direct console connection
- Program integrity review (comparison of running program against available backups)
- Gateway and firewall configuration audit

- Credential and access control review
- Interviews with two plant operators and the contracted systems integrator

All on-site work was conducted during normal operating hours with plant operations staff present. No testing caused process disruption, controller faults, or service interruption.

Facility Profile

FIELD	DETAIL
Operator	Cedar Ridge Regional Water Authority (CRRWA)
Facility	Cedar Ridge Water Treatment Plant
Type	Surface water treatment (conventional)
Population served	Approximately 14,200 residents
Treatment capacity	4.2 MGD (design), approximately 2.8 MGD (average day demand)
Source water	Cedar Ridge Reservoir
Processes automated	Chemical dosing (chlorine, fluoride, coagulant), filtration backwash sequencing, clearwell level control, high-service pump control
Staffing	3 full-time operators, 1 contracted systems integrator (remote, on-call)
Remote access model	Microhard cellular gateway with NAT/port forwarding (pre-remediation)

Validated Asset Inventory

The following asset inventory was compiled from physical inspection and confirmed against CIP identity responses, device nameplates, and operating system queries.

Controllers

ID	DEVICE	LOCATION	IP ADDRESS	FIRMWARE	FUNCTION	SERIAL
PLC-01	CompactLogix 1769-L18ER/A	Main control panel, filter gallery	192.168.1.30	20.011	Chemical dosing, coagulant feed, clearwell level	0x60a7f31d
PLC-02	CompactLogix 1769-L18ER/B	Main control panel, filter gallery	192.168.1.3	20.011	Filtration backwash sequencing, high-service pumps	0x60b412c8

HMI and Engineering

ID	DEVICE	LOCATION	OS	FUNCTION	NOTES
HMI-01	Dell OptiPlex 7070	Control room	Windows 10 Pro 21H2 (build 19044)	FactoryTalk View SE Client, Studio 5000 v28	End-of-life OS. No endpoint protection installed.

Historian and Data

ID	DEVICE	LOCATION	OS	FUNCTION	NOTES
HIST-01	Dell PowerEdge T340	Server closet (unlocked)	Windows Server 2016 Standard	FactoryTalk Historian SE	SQL Server Express with default SA password. No access restrictions.

Network Equipment

ID	DEVICE	LOCATION	IP ADDRESS	FUNCTION	NOTES
GW-01	Microhard BulletPlus	Rooftop equipment enclosure	192.168.1.1 (LAN), public IP redacted	Cellular gateway, internet uplink	Verizon Business LTE. NAT/port forwarding to PLC subnet.
RADIO-01	XetaWave XETA9-CM	Rooftop mast	192.168.1.50	Point-to-point telemetry link to booster station	Management UI on port 602. No authentication.
SW-01	Stratix 2000 (unmanaged)	Main control panel	N/A	OT network switch	8-port unmanaged. No VLAN capability.

Network Diagram (Simplified)

```
[Internet] ── Verizon LTE ── [GW-01 Microhard BulletPlus]
                                        |
                              [SW-01 Stratix 2000]
                             /    |    |    \
                        PLC-01 PLC-02 HMI-01 HIST-01
```

```
                                        |
                                [RADIO-01 XetaWave]
                                        |
                            [Booster Station RTU]
```

All devices reside on a single flat 192.168.1.0/24 subnet with no VLANs, no internal firewalling, and no access control between devices. The Stratix 2000 is an unmanaged switch with no segmentation capability.

External Vulnerability Findings

The following findings were initially identified through passive external reconnaissance on April 14, 2026, and validated on-site during the May assessment. Phase 1 compensating controls (ACLs on the Microhard gateway) were applied on April 23 to 25, 2026, prior to on-site work. Each finding notes its current status.

Finding EXT-1: CVE-2021-22681 (Authentication Bypass on EtherNet/IP)

FIELD	DETAIL
Severity	CRITICAL
CVE	CVE-2021-22681
CVSS v3.1	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-522 (Insufficiently Protected Credentials)
Affected Devices	PLC-01, PLC-02
CISA KEV	Yes. Federal remediation deadline has passed.
Status	Compensating control in place. Full remediation pending firmware upgrade.

Description. Rockwell Automation Logix Controllers use a key-based authentication mechanism between Studio 5000 Logix Designer and the controller. This mechanism is insufficiently protected. An

unauthenticated remote attacker can bypass the verification process and establish an authenticated session with the controller. Once connected, the attacker can read controller logic, modify controller logic, change controller state (including Run, Program, and Test modes), and manipulate process variables.

On-Site Validation. Confirmed. Both controllers responded to unauthenticated CIP identity requests during on-site verification via direct Ethernet connection. Firmware version 20.011 confirmed on both units via controller faceplate and CIP identity object. The controllers do not support CIP Security at this firmware level.

Risk Context. This vulnerability is in the CISA Known Exploited Vulnerabilities catalog, confirming exploitation in the wild. For this facility, unauthorized logic modification could alter chlorine dosing setpoints, disable filtration backwash sequences, or override clearwell level alarms. The compensating control (ACL blocking inbound 44818 traffic) is currently effective but depends on a single network device (GW-01). No defense-in-depth exists.

Compensating Control Applied. ACL on GW-01 drops all inbound traffic to 44818/tcp and 44818/udp except from the designated operator jump host. Verified by external scan on April 26, 2026.

Full Remediation. Coordinate with Rockwell Automation to upgrade firmware to a version supporting CIP Security (Logix Designer v33+). If the 1769-L18ER platform cannot support CIP Security, deploy an industrial firewall between GW-01 and SW-01 and document formal risk acceptance per IEC 62443-3-3 SR 1.1.

References.

- NVD: https://nvd.nist.gov/vuln/detail/CVE-2021-22681
- CISA Advisory: ICSA-21-056-03
- Rockwell Automation: PN1596

Finding EXT-2: CVE-2022-1161 (Stealth Logic Modification)

FIELD	DETAIL
Severity	CRITICAL
CVE	CVE-2022-1161
CVSS v3.1	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

FIELD	DETAIL
CWE	CWE-829 (Inclusion of Functionality from Untrusted Control Sphere)
Affected Devices	PLC-01, PLC-02
CISA KEV	No
Status	Compensating control in place. Full remediation pending firmware upgrade.

Description. Studio 5000 Logix Designer stores the user-readable program code in a different location from the executable compiled code on the controller. An attacker with write access can alter the compiled code that actually executes while leaving the displayed source code unchanged. This is the “Evil PLC” attack class. An engineer reviewing the program in Studio 5000 sees the intended logic while the controller executes attacker-supplied logic.

On-Site Validation. Confirmed. Firmware 20.011 does not support Controller Change Detection. No mechanism exists to detect divergence between displayed and executing code without a manual program upload and offline comparison. See Finding INT-4 for the related absence of program backups.

Risk Context. Combined with EXT-1, this enables an attacker to silently modify chemical dosing, pump sequencing, or alarm thresholds with no operator-visible indication. This is the finding most likely to cause a slow-developing public health event.

Compensating Control Applied. Same ACL as EXT-1 (blocking 44818 inbound). Additionally, a controller integrity baseline comparison was attempted during on-site assessment (see Finding INT-4 for results).

Full Remediation. Upgrade firmware to a version supporting Controller Change Detection. Establish a golden image baseline and a monthly comparison procedure.

References.

- NVD: https://nvd.nist.gov/vuln/detail/CVE-2022-1161
- CISA Advisory: ICSA-22-090-05

Finding EXT-3: CVE-2019-10952 (Remote Code Execution via Embedded Web Server)

FIELD	DETAIL
Severity	CRITICAL
CVE	CVE-2019-10952
CVSS v3.1	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-787 (Out-of-bounds Write)
Affected Devices	PLC-01, PLC-02
CISA KEV	No
Status	Compensating control in place. Full remediation pending firmware upgrade.

Description. A stack-based buffer overflow exists in the CompactLogix 5370 family embedded web server. A crafted HTTP or HTTPS request can trigger the overflow, potentially achieving remote code execution or denial of service.

On-Site Validation. Confirmed. Both controllers serve the embedded web interface (lighttpd) on ports 80 and 443. Firmware 20.011 is within the affected range (20.011 through 30.014). The web server was confirmed accessible on the internal network during on-site testing.

Compensating Control Applied. ACL on GW-01 drops all inbound traffic to 80/tcp and 443/tcp. Verified by external scan on April 26, 2026. Note: the web server remains accessible from the internal OT network, which is a residual risk given the flat network architecture (see Finding INT-1).

Full Remediation. Upgrade firmware above version 30.014. If upgrade is not feasible, disable the embedded web server on both controllers and maintain the external ACL permanently.

References.

- NVD: https://nvd.nist.gov/vuln/detail/CVE-2019-10952
- CISA Advisory: ICSA-19-120-01

Finding EXT-4: XetaWave Radio Management Interface Exposed (Pre-Remediation)

FIELD	DETAIL
Severity	HIGH
Affected Device	RADIO-01
Status	Compensating control in place.

Description. Port 602/tcp on the public IP served the XetaWave industrial radio management UI with no authentication challenge. This interface controls the configuration of the point-to-point wireless link carrying SCADA traffic between the treatment plant and the booster station.

On-Site Validation. Confirmed. The XetaWave XETA9-CM management interface was verified on-site. The radio uses default configuration with no authentication on the management UI and no encryption on the data link.

Compensating Control Applied. ACL on GW-01 blocks inbound traffic to 602/tcp. On-site recommendation: enable management authentication and data link encryption on the XetaWave radio.

Finding EXT-5: Open DNS Resolver on SCADA Gateway

FIELD	DETAIL
Severity	MEDIUM
Affected Device	GW-01
Status	Compensating control in place.

Port 53/tcp answered recursive DNS queries from the public internet. This creates DNS amplification attack participation risk and indicates a permissive default service configuration on the gateway.

Compensating Control Applied. DNS service restricted to internal interface only during Phase 1. Verified on April 26, 2026.

Finding EXT-6: Cleartext Authentication Services on Internet-Facing Equipment (Pre-Remediation)

FIELD	DETAIL
Severity	HIGH
Affected Devices	GW-01, PLC-01, PLC-02
Status	Compensating control in place.

FTP (21/tcp) and Telnet (23/tcp) were exposed on both public IPs with cleartext credential transmission. The “UserDevice” login prompt indicated default Microhard gateway credentials.

On-Site Validation. Confirmed. The Microhard gateway was configured with the vendor default username and password. These credentials were rotated during Phase 1.

Compensating Control Applied. FTP and Telnet services disabled on GW-01. All gateway credentials rotated. Default “UserDevice” credentials replaced with strong unique passwords.

Internal Vulnerability Findings

The following findings were identified during the on-site assessment (May 5 to 9, 2026). These vulnerabilities are not visible through external reconnaissance and represent the internal attack surface an adversary would encounter after gaining initial access.

Finding INT-1: No Network Segmentation in OT Environment

FIELD	DETAIL
Severity	CRITICAL
Affected	Entire OT network

FIELD	DETAIL
IEC 62443-3-3	SR 5.1 (Network Segmentation)

Description. All OT devices (PLCs, HMI, historian, cellular gateway, radio) share a single flat 192.168.1.0/24 subnet connected through an unmanaged Stratix 2000 switch. No VLANs, no internal firewall, and no access control lists exist between any internal devices. Any device on the network can communicate with any other device on any port.

Risk Context. This architecture means that compromise of any single device provides unrestricted access to all others. The HMI workstation (which has a web browser and USB ports) sits on the same broadcast domain as the PLCs controlling chemical dosing. An attacker who compromises the HMI through a phishing email, infected USB drive, or browser exploit would have direct, unfiltered access to both PLCs over EtherNet/IP.

IEC 62443-3-3 SR 5.1 requires network segmentation with defined zones and conduits. The current architecture does not meet this requirement.

Remediation. Deploy an industrial firewall or managed switch between logical zones: (1) PLC/controller zone, (2) HMI/engineering zone, (3) historian/data zone, (4) network edge/gateway zone. Define conduit rules per IEC 62443-3-3. The unmanaged Stratix 2000 should be replaced with a managed switch supporting VLANs.

Finding INT-2: HMI Workstation Running End-of-Life Operating System with No Endpoint Protection

FIELD	DETAIL
Severity	CRITICAL
Affected Device	HMI-01
CISA CPG	5.A (Asset Inventory), 1.A (Mitigate Known Vulnerabilities)

Description. The HMI workstation (Dell OptiPlex 7070) runs Windows 10 Pro version 21H2 (build 19044), which reached end of support on June 13, 2023. The system has received no security updates since approximately January 2025. No endpoint protection software (antivirus, EDR, or application whitelisting) is installed.

On-Site Observation. Windows Update history confirmed no updates installed since January 2025. The system was checked for antivirus software (Windows Defender was disabled, no third-party AV present). The HMI workstation runs FactoryTalk View SE Client and has Studio 5000 v28 installed for controller programming.

Risk Context. The HMI workstation is the primary operator interface and the only engineering workstation for both PLCs. It has USB ports enabled (see INT-5), a web browser installed, and sits on the same flat network as the controllers (INT-1). Three years of unpatched Windows vulnerabilities on a system with direct PLC programming capability represents a significant lateral movement target. An attacker with access to this workstation has Studio 5000 and could reprogram both controllers.

Remediation. Upgrade to a supported Windows version (Windows 10 LTSC 2021 or Windows 11 LTSC). Deploy application whitelisting (e.g., Carbon Black App Control or Windows Defender Application Control) rather than traditional AV, consistent with NIST SP 800-82 Rev 3 recommendations for OT endpoints. Establish a patch management procedure for the HMI workstation on a quarterly cycle at minimum.

Finding INT-3: SCADA Historian Accessible with Default Database Credentials

FIELD	DETAIL
Severity	CRITICAL
Affected Device	HIST-01
CISA CPG	2.A (Changing Default Passwords)

Description. The FactoryTalk Historian SE installation on HIST-01 uses a SQL Server Express backend with the default SA (system administrator) password unchanged from the vendor installation. The database accepts connections from any device on the 192.168.1.0/24 subnet. No additional authentication or role-based access controls are configured.

On-Site Observation. Verified by connecting to the SQL Server instance from the HMI workstation using the default SA credentials documented in FactoryTalk Historian installation guides. Full read/write access to all historian tables was confirmed. Process data, alarm history, and operator action logs are stored in this database.

Risk Context. The historian contains historical process data that could be used for reconnaissance (learning normal operating parameters before modifying them) or tampered with to conceal evidence of a controller logic attack (INT-1 + EXT-2). An attacker with database access could also modify alarm history

to mask an ongoing attack. The server closet containing HIST-01 was observed unlocked during all five days of on-site assessment.

Remediation. Change the SA password immediately. Disable the SA account and create named service accounts with least-privilege roles. Restrict SQL Server connections to the HMI subnet only (once segmentation from INT-1 is implemented). Lock the server closet.

Finding INT-4: No Controller Program Backups or Change Management

FIELD	DETAIL
Severity	CRITICAL
Affected Devices	PLC-01, PLC-02
IEC 62443-3-3	SR 3.4 (Software and Information Integrity)

Description. No documented backup of either PLC program exists at the facility. The contracted systems integrator was contacted during the assessment and confirmed that the most recent program backup in their records is from July 2024 (approximately 22 months old). No formal change management procedure exists for controller program modifications. Operators reported that the integrator occasionally makes changes remotely via the cellular gateway but does not provide change documentation or updated backups.

On-Site Observation. A program upload from both controllers was performed during the assessment and saved as the initial integrity baseline. The uploaded programs were compared to the July 2024 backup provided by the integrator. The comparison showed modifications to four rungs in PLC-01 related to chlorine dosing setpoint ranges and two rungs in PLC-02 related to backwash timing. These modifications were verbally confirmed by the integrator as changes made in November 2025, but no written change record exists.

Risk Context. Without current backups, recovery from a controller compromise or hardware failure would require the integrator to reprogram both controllers from scratch or from a 22-month-old baseline. The absence of change management means there is no way to verify whether any unauthorized modifications have been made to the running programs. This directly enables the threat described in EXT-2 (CVE-2022-1161, stealth logic modification).

Remediation. Store the baseline programs uploaded during this assessment as the new golden images. Establish a formal change management procedure requiring: (1) written change request before any

modification, (2) program backup before and after every change, (3) comparison of running program against golden image on a monthly schedule. Store backups in a location separate from the OT network (e.g., encrypted USB in a locked cabinet or secure cloud storage).

Finding INT-5: USB Ports Enabled on HMI Workstation with No Media Controls

FIELD	DETAIL
Severity	HIGH
Affected Device	HMI-01
IEC 62443-3-3	SR 2.3 (Use Control for Portable and Mobile Devices)

Description. All USB ports on the HMI workstation are active with no group policy restrictions, no USB device whitelisting, and no removable media controls. During the assessment, a USB keyboard, USB mouse, and a personal USB flash drive belonging to an operator were observed connected to the workstation simultaneously.

Risk Context. USB-borne malware is a well-documented attack vector in OT environments. The Stuxnet attack and multiple subsequent ICS campaigns used USB media as the initial access vector. Combined with the absence of endpoint protection on HMI-01 (INT-2), any infected USB device connected to the workstation could execute without restriction.

Remediation. Implement a USB device whitelisting policy that permits only authorized keyboards and mice. Disable USB mass storage via Group Policy or BIOS configuration. If USB file transfer is operationally required, establish a media sanitization kiosk procedure.

Finding INT-6: Shared Operator Credentials Across All Staff

FIELD	DETAIL
Severity	HIGH
Affected	HMI-01, GW-01, PLC-01, PLC-02

FIELD	DETAIL
CISA CPG	2.A (Changing Default Passwords)

Description. All three plant operators share a single Windows login for the HMI workstation, a single FactoryTalk View SE login, and a single set of credentials for the Microhard gateway. Individual operator accounts do not exist. The same credentials are also shared with the contracted systems integrator for remote access.

On-Site Observation. Confirmed through operator interviews. All three operators reported using the same username and password for daily operations. No operators have individual accounts. The integrator uses the same credentials when connecting remotely. Operators reported the credentials have been the same for “at least two years.”

Risk Context. Shared credentials eliminate accountability and audit trail capability. If a controller program is modified (legitimately or maliciously), there is no way to attribute the action to a specific individual. This also means credential compromise affects all users simultaneously, and password rotation requires coordinating with all staff and the integrator.

Remediation. Create individual named accounts for each operator, the integrator, and any other personnel requiring access. Assign role-based permissions (operator vs. engineer vs. administrator). Implement a password policy requiring unique passwords with rotation at least annually. For remote integrator access, require MFA through the planned VPN architecture (Phase 3).

Finding INT-7: No OT-Specific Logging or Monitoring

FIELD	DETAIL
Severity	HIGH
Affected	Entire OT network
IEC 62443-3-3	SR 6.1 (Audit Log Accessibility), SR 6.2 (Continuous Monitoring)

Description. No logging infrastructure exists for the OT network. The Microhard gateway logs are configured at default verbosity and rotate after 64 KB (approximately 2 to 3 days of entries). No syslog

server, SIEM, or network monitoring tool is deployed. Controller access events, program changes, and network connections are not recorded anywhere.

On-Site Observation. Gateway logs were reviewed during the assessment. The oldest log entry available was from May 3, 2026 (two days before the assessment began). No historical logs exist. The FactoryTalk Historian logs process data (temperatures, flow rates, chemical levels) but does not log security events, user logins, or controller access events.

Risk Context. Without logging, there is no way to detect unauthorized access, investigate a security incident, or comply with the audit and accountability requirements of IEC 62443-3-3 or NIST SP 800-82. If an attacker had accessed the controllers at any point in the past, there would be no evidence of it.

Remediation. Deploy a syslog server on the historian or a dedicated device. Configure the Microhard gateway, HMI workstation, and historian to forward security logs. At minimum, log: gateway connection events, Windows logon/logoff, FactoryTalk user actions, and controller access events (if supported by the Studio 5000 version). Retain logs for a minimum of 90 days. Longer term, evaluate OT network monitoring solutions (passive network sensors) for deeper visibility.

Finding INT-8: XetaWave Radio Link Operates Without Encryption

FIELD	DETAIL
Severity	MEDIUM
Affected Device	RADIO-01
IEC 62443-3-3	SR 3.1 (Communication Integrity)

Description. The XetaWave XETA9-CM point-to-point radio link between the treatment plant and the booster station transmits SCADA telemetry data without encryption. The radio operates in the 900 MHz ISM band with no data link encryption configured.

On-Site Observation. Radio configuration was reviewed via the management interface (port 602, internal access). AES encryption is supported by the XE900 hardware but is not enabled. The link carries Modbus RTU traffic for the booster station RTU.

Risk Context. An attacker within radio range could intercept or inject Modbus commands on the wireless link. The practical likelihood is reduced by the directional antenna configuration and the 900 MHz frequency, but the capability exists.

Remediation. Enable AES-256 encryption on the XetaWave data link. This requires configuration changes on both ends of the radio link and a brief interruption to the booster station telemetry (estimated 15 to 30 minutes).

Finding INT-9: Server Closet Physical Access Not Controlled

FIELD	DETAIL
Severity	MEDIUM
Affected	HIST-01, network equipment

Description. The server closet containing the historian server (HIST-01), network switch (SW-01), and patch panel is located in an unlocked utility room accessible to all plant staff and visitors in the operations area.

On-Site Observation. The closet door was observed open and unlocked during all five days of on-site assessment. Operators confirmed there is no lock on the closet and no access log. The closet is in the same hallway as the operator break room.

Remediation. Install a keyed or badge-access lock on the server closet. Restrict access to authorized personnel only. While physical security was out of scope for this assessment, this finding was noted due to its direct impact on the security of OT assets.

Controller Integrity Baseline

During the on-site assessment, a program upload was performed on both controllers and compared to the most recent backup available from the contracted systems integrator (dated July 2024).

CONTROLLER	RUNNING PROGRAM	LAST BACKUP	DIFFERENCES FOUND	ASSESSMENT
PLC-01	Uploaded May 6, 2026	July 2024	4 rungs modified (chlorine dosing setpoint range changes)	Changes verbally attributed to integrator, November 2025. No written change record. No evidence of unauthorized modification, but cannot be conclusively ruled out.
PLC-02	Uploaded May 7, 2026	July 2024	2 rungs modified (backwash timing adjustments)	Changes verbally attributed to integrator, November 2025. No written change record. No evidence of unauthorized modification, but cannot be conclusively ruled out.

The programs uploaded during this assessment have been saved as the new golden image baseline. Future comparisons should be performed monthly against this baseline, with any differences investigated and documented before acceptance.

Risk Matrix

Critical Findings

ID	FINDING	LIKELIHOOD	IMPACT	RISK	STATUS
EXT-1	CVE-2021-22681 (Auth Bypass, KEV)	Very High	Critical	CRITICAL	Compensating control
EXT-2	CVE-2022-1161 (Stealth Logic Mod)	High	Critical	CRITICAL	Compensating control
EXT-3	CVE-2019-10952 (Web Server RCE)	High	Critical	CRITICAL	Compensating control
INT-1	No network segmentation	High	Critical	CRITICAL	Open
INT-2	HMI end-of-life OS, no endpoint protection	High	Critical	CRITICAL	Open
INT-3	Historian default database credentials	High	High	CRITICAL	Open
INT-4	No PLC backups or change management	Medium	Critical	CRITICAL	Baseline established

High Findings

ID	FINDING	LIKELIHOOD	IMPACT	RISK	STATUS
EXT-4	XetaWave radio UI exposed (pre-remediation)	High	High	HIGH	Compensating control
EXT-6	Cleartext FTP/ Telnet, default credentials	High	High	HIGH	Compensating control
INT-5	USB ports enabled, no media controls	Medium	High	HIGH	Open
INT-6	Shared operator credentials	Medium	High	HIGH	Open
INT-7	No OT logging or monitoring	Medium	High	HIGH	Open

Medium Findings

ID	FINDING	LIKELIHOOD	IMPACT	RISK	STATUS
EXT-5	Open DNS resolver on gateway	Medium	Medium	MEDIUM	Compensating control
INT-8	Radio link unencrypted	Low	Medium	MEDIUM	Open
INT-9	Server closet unlocked	Medium	Medium	MEDIUM	Open

Exposure Amplifiers

CONDITION	IMPACT
Flat network architecture	Compromise of any device provides unrestricted access to all OT assets
Single engineering workstation	HMI-01 is both the operator console and the PLC programming station
No logging or monitoring	Intrusions cannot be detected or investigated
Shared credentials	Actions cannot be attributed to individuals
No change management	Unauthorized controller modifications cannot be distinguished from authorized ones

Recommended Actions

Completed (Phase 1 Compensating Controls)

ACTION	FINDING	DATE
ACL blocking inbound 44818/tcp and 44818/udp	EXT-1, EXT-2	April 23, 2026
ACL blocking inbound 80/tcp and 443/tcp	EXT-3	April 23, 2026
ACL blocking inbound 602/tcp	EXT-4	April 23, 2026
FTP and Telnet services disabled	EXT-6	April 24, 2026

ACTION	FINDING	DATE
Gateway credentials rotated	EXT-6	April 24, 2026
DNS resolver restricted to internal interface	EXT-5	April 25, 2026

Priority 1: Immediate (Within 30 Days)

These actions can be completed without plant downtime or major procurement.

1. **Change historian SA password and disable SA account** (INT-3). Create named service accounts with least-privilege roles. Restrict SQL connections to local subnet.
2. **Create individual operator accounts** (INT-6). Named Windows logins, FactoryTalk accounts, and gateway accounts for each operator and the integrator.
3. **Lock the server closet** (INT-9). Install keyed access.
4. **Disable USB mass storage on HMI-01** (INT-5). Group Policy or BIOS restriction.
5. **Establish a formal change management procedure for PLC programs** (INT-4). Written change requests, before/after backups, monthly golden image comparison.

Priority 2: Next Maintenance Window (30 to 60 Days)

1. **Deploy network segmentation** (INT-1). Replace the unmanaged Stratix 2000 with a managed switch or deploy an industrial firewall. Establish zones per IEC 62443: controller, HMI/engineering, historian/data, network edge.
2. **Replace NAT/port-forwarding with VPN-only remote access** (EXT-1 through EXT-6). Certificate-based VPN on the Microhard gateway. MFA-enabled jump host.
3. **Upgrade or rebuild HMI-01** (INT-2). Supported Windows version, application whitelisting, patch management procedure.
4. **Enable AES encryption on the XetaWave radio link** (INT-8).
5. **Deploy logging infrastructure** (INT-7). Syslog server, 90-day log retention, security event forwarding from gateway, HMI, and historian.

Priority 3: Next Capital Cycle (60 to 180 Days)

1. **Upgrade PLC firmware** (EXT-1, EXT-2, EXT-3). Coordinate with Rockwell Automation for the latest supported firmware on the 1769-L18ER platform. Enable CIP Security and Controller Change Detection if supported.

2. **Deploy OT network monitoring** (INT-7). Passive network sensor for deep packet inspection of CIP, Modbus, and other industrial protocols.

Standards Compliance Summary

STANDARD	REQUIREMENT	CURRENT STATE	GAP
IEC 62443-3-3 SR 1.1	Human user identification and authentication	Shared credentials, no individual accounts	Non-compliant
IEC 62443-3-3 SR 2.3	Use control for portable/ mobile devices	USB ports unrestricted	Non-compliant
IEC 62443-3-3 SR 3.1	Communication integrity	Radio link unencrypted, no CIP Security	Non-compliant
IEC 62443-3-3 SR 3.4	Software and information integrity	No backups, no change management	Non-compliant
IEC 62443-3-3 SR 5.1	Network segmentation	Flat network, no zones or conduits	Non-compliant
IEC 62443-3-3 SR 6.1	Audit log accessibility	No logging infrastructure	Non-compliant
IEC 62443-3-3 SR 6.2	Continuous monitoring	No monitoring deployed	Non-compliant
NIST SP 800-82 Rev 3	OT network architecture	No segmentation, no DMZ	Non-compliant
NIST SP 800-82 Rev 3	Patch management	HMI unpatched, controllers at vulnerable firmware	Non-compliant
CISA CPG 1.A	Mitigate known vulnerabilities	3 Critical CVEs (compensating controls in place)	Partial

STANDARD	REQUIREMENT	CURRENT STATE	GAP
CISA CPG 2.A	Change default passwords	Historian SA default, credentials recently rotated on gateway	Partial
CISA CPG 2.F	No exploitable services on internet	Compensating controls applied, architectural remediation pending	Partial

Appendix A: CIP Identity Responses

PLC-01

```
Vendor ID:        1 (Rockwell Automation / Allen-Bradley)
Device Type:      14 (Programmable Logic Controller)
Product Code:     165
Product Name:     1769-L18ER/A LOGIX5318ER
Revision:         20.011
Serial Number:    0x60a7f31d
Internal IP:      192.168.1.30
```

PLC-02

```
Vendor ID:        1 (Rockwell Automation / Allen-Bradley)
Device Type:      14 (Programmable Logic Controller)
Product Code:     165
Product Name:     1769-L18ER/B LOGIX5318ER
Revision:         20.011
Serial Number:    0x60b412c8
Internal IP:      192.168.1.3
```

Appendix B: External Service Observations (Pre-Remediation)

The following services were observed during external passive reconnaissance on April 14, 2026, prior to compensating controls. This appendix is retained for completeness. All listed services were blocked or disabled during Phase 1 (April 23 to 25, 2026).

PLC-01 (198.51.100.10)

PORT	PROTOCOL	SERVICE	NOTES
21/tcp	FTP	Embedded	MAC: 00:0F:92:4D:A1:7C (Rockwell OUI). Disabled April 24.
22/tcp	SSH	Dropbear 2020.81	Credentials rotated April 24.
23/tcp	Telnet	BusyBox telnetd	“UserDevice login:”. Disabled April 24.
53/tcp	DNS	Open resolver	Restricted to internal April 25.
80/tcp	HTTP	lighttpd	Blocked April 23.
443/tcp	HTTPS	lighttpd	Blocked April 23.
44818/tcp	EtherNet/IP	Allen-Bradley CIP	Blocked April 23.
44818/udp	EtherNet/IP	Allen-Bradley CIP	Blocked April 23.

PLC-02 (198.51.100.11)

PORT	PROTOCOL	SERVICE	NOTES
21/tcp	FTP	Embedded	MAC: 00:0F:92:6E:B3:92 (Rockwell OUI). Disabled April 24.
22/tcp	SSH	Dropbear 2020.81	Credentials rotated April 24.
23/tcp	Telnet	BusyBox telnetd	“UserDevice login:”. Disabled April 24.
53/tcp	DNS	Open resolver	Restricted to internal April 25.
80/tcp	HTTP	lighttpd	Blocked April 23.
443/tcp	HTTPS	lighttpd	Blocked April 23.
602/tcp	HTTP	XetaWave	Blocked April 23.
44818/tcp	EtherNet/IP	Allen-Bradley CIP	Blocked April 23.
44818/udp	EtherNet/IP	Allen-Bradley CIP	Blocked April 23.

Appendix C: Data Sources

SOURCE	TYPE	DETAIL
Passive intelligence (aggregated public sources)	External reconnaissance	Internet-indexed metadata for both IPs. Observed April 14, 2026.

SOURCE	TYPE	DETAIL
On-site physical inspection	Internal assessment	May 5 to 9, 2026. All OT assets physically inspected and documented.
Controller program upload	Integrity verification	Programs uploaded from PLC-01 and PLC-02 via direct Ethernet connection.
Network traffic capture	Passive analysis	48-hour packet capture on SW-01 span port (mirrored).
Operator interviews	Personnel assessment	Two operators interviewed regarding access procedures, change management, and incident response.
Integrator consultation	Technical verification	Contracted integrator provided July 2024 program backups and confirmed November 2025 changes.
National Vulnerability Database (NIST NVD)	Vulnerability database	CVE details, CVSS scores, CWE classifications, affected product versions.
CISA Known Exploited Vulnerabilities Catalog	Exploited vulnerabilities list	CVE-2021-22681 confirmed in catalog.
CISA ICS Advisories	Vendor coordinated disclosure	ICSA-21-056-03, ICSA-22-090-05, ICSA-19-120-01.

Disclaimer

This report was produced by Sentinel OT based on a combination of passive external reconnaissance and authorized on-site assessment conducted with full cooperation and access provided by Cedar Ridge Regional Water Authority. External findings are based on publicly available, passively collected internet metadata. Internal findings are based on direct physical inspection, configuration review, and interviews.

Sentinel OT does not guarantee the completeness of these findings. Additional vulnerabilities may exist in areas outside the defined scope (IT network, physical security, application logic).

This report is classified as Confidential and is intended solely for authorized personnel at Cedar Ridge Regional Water Authority. Distribution to unauthorized parties is prohibited.

Sample document. Cedar Ridge Regional Water Authority is a fictional operator used to illustrate the format and depth of a Sentinel OT comprehensive vulnerability assessment report. No real utility, facility, or IP address is depicted. Addresses 198.51.100.10 and 198.51.100.11 are drawn from the IETF RFC 5737 documentation range reserved for examples.

Report ID: `pbcwud_cedar-ridge_sample_2026-05-12`